

Company: Alvin Tech

Internal Audit Report

Report Date: April 1, 2025

Audit Period: January - March 2025

Prepared by: Internal Audit Department

Executive Summary

Following last year's regulatory audit findings, the Internal Audit Department conducted a comprehensive review of Alvin Tech's security controls, policies, and compliance status. This audit was performed to assess progress in addressing previously identified issues and to provide management with an objective evaluation of the company's current security posture.

The audit found that while significant improvements have been made, several areas still require attention before the company can demonstrate full compliance with regulatory requirements and industry standards, particularly PCI DSS.

Audit Scope

1. Review of security patching and vulnerability management
2. Assessment of access control mechanisms and privilege management
3. Evaluation of data protection controls for virtual card and wallet services
4. Review of incident response capabilities
5. Validation of compliance with PCI DSS requirements
6. Assessment of third-party vendor management

Key Findings

1. Security Patching and Vulnerability Management

Rating: Partially Satisfactory

Positive Observations:

- Systematic approach to patching critical systems
- 87% of identified vulnerabilities have been remediated
- Improved vulnerability scanning and tracking processes

Areas of Concern:

- Several critical systems remain unpatched due to compatibility issues
- No formal exception management process for systems that cannot be patched
- Testing environment remains vulnerable and connected to production network
- Patch verification process is inconsistent

Recommendations:

- Establish formal exception handling process with risk assessments
- Implement network segmentation for unpatched systems
- Develop a comprehensive vulnerability management program

2. Access Control and Privilege Management

Rating: Needs Improvement

Positive Observations:

- Role-based access control (RBAC) implemented for main applications
- Privileged access management solution deployed
- Regular user access reviews implemented for critical systems

Areas of Concern:

- Several shared accounts still in use for administrative functions
- Excessive privileges found on 23% of sampled user accounts
- No automated monitoring of privilege escalation
- Password policies below industry standards for internal systems
- Segregation of duties conflicts identified in payment processing functions

Recommendations:

- Eliminate all shared accounts
- Implement principle of least privilege across all systems
- Enhance monitoring of privileged accounts
- Strengthen password policies to align with industry standards

3. Data Protection

Rating: Satisfactory

Positive Observations:

- Card data encryption meets PCI DSS requirements
- Data loss prevention (DLP) tools deployed
- Sensitive data inventory has been created and maintained

Areas of Concern:

- Test environments contain some unmasked cardholder data
- Key management procedures lack proper documentation
- Data retention practices inconsistent across systems

Recommendations:

- Remove all sensitive data from test environments
- Formalize key management procedures
- Standardize data retention practices across the organization

4. Incident Response**Rating: Satisfactory****Positive Observations:**

- Updated incident response plan in place
- Regular tabletop exercises conducted
- Improved incident detection capabilities

Areas of Concern:

- Limited evidence of testing the full incident response plan
- Some incident response team members lack formal training
- Third-party breach notification procedures incomplete

Recommendations:

- Conduct full-scale incident response simulations
- Provide formal training to all incident response team members
- Enhance third-party breach notification procedures

5. PCI DSS Compliance

Rating: Needs Improvement

Positive Observations:

- Significant progress in addressing previous PCI DSS findings
- Improved cardholder data environment (CDE) scoping
- Enhanced security awareness training

Areas of Concern:

- Four PCI DSS requirements still not fully met
- Network segmentation controls inadequate
- Vendor management program incomplete
- Self-assessment process lacks rigor

Recommendations:

- Address remaining PCI DSS compliance gaps as priority
- Strengthen network segmentation controls
- Enhance vendor management program
- Improve self-assessment methodology

6. Third-Party Vendor Management

Rating: Needs Improvement

Positive Observations:

- Vendor inventory has been created
- Critical vendors identified
- Initial risk assessments conducted

Areas of Concern:

- Incomplete due diligence for 5 critical service providers
- No continuous monitoring of vendor security practices
- Contract security requirements inconsistently applied
- No formal process for vendor incident notification

Recommendations:

- Complete due diligence for all critical vendors
- Implement continuous vendor security monitoring
- Standardize security requirements in contracts
- Establish formal vendor incident notification processes

Management Response

Management has acknowledged the findings in this report and has committed to addressing all identified issues prior to the external audit. A detailed remediation plan with specific timelines has been developed for each finding.

The Executive Leadership Team has prioritized the following actions:

1. Resolving remaining critical and high-risk vulnerabilities
2. Addressing PCI DSS compliance gaps
3. Enhancing access control mechanisms
4. Improving third-party vendor management

Conclusion

While Alvin Tech has made substantial progress in addressing the security and compliance issues identified in last year's regulatory audit, several significant gaps remain. These issues must be addressed promptly to achieve full compliance and protect the company's virtual card and wallet services.

The Internal Audit Department will continue to monitor progress and provide regular updates to management and the Board of Directors.

Prepared by:

Jennifer Liu, *Head of Internal Audit*

Reviewed by:

Robert Garcia, *Audit Committee Chair*